Web Application Security Assessment Report

Vulnerability: Sensitive Information Disclosure via Improper Error Handling (Unauthenticated)

1. Executive Summary

A security assessment identified a high-severity information disclosure vulnerability in a web application due to improper error handling. Unauthenticated users can trigger backend errors and retrieve sensitive internal details, including stack traces and application secrets. This exposure significantly increases the risk of further attacks and system compromise.

2. Vulnerability Overview

ID	Vulnerability	Severity	Status
VULN-01	Information Disclosure via Stack Trace	High	Open

3. Affected Component:

AI Chatbot Interface (Unauthenticated endpoint)

4. Attack Narrative

During testing of application functionality, it was observed that certain inputs triggered unhandled exceptions. The server responded with detailed error messages, exposing backend stack traces, internal file paths, and sensitive configuration values. This confirms that the application lacks proper error handling controls, allowing internal system details to be disclosed to unauthenticated users.

5. Steps to Reproduce

1. Navigate to the AI chatbot interface
2. Enter input such as: "hello" or malformed input
3. Submit the request
4. Observe HTTP 500 Internal Server Error response
5. Stack trace and sensitive data are exposed in response

6. Impact

- Exposure of internal application structure and file paths
- Disclosure of sensitive secrets (e.g., application keys, tokens)
- Increased risk of targeted attacks due to system fingerprinting
- Potential session/token compromise if exposed secrets are reused
- An attacker may leverage disclosed secrets to perform further attacks such as token forgery or authentication bypass, depending on implementation.

7. Technical Details

The error response revealed:

- Backend Technology: Python / Flask
- Database: SQLite
- Internal file references (e.g., application source paths)
- Sensitive configuration values including:
    - Application secret keys
    - JWT-related keys
    - Debug configuration settings
    - Session management details

This information was directly exposed in the HTTP response without authentication.

8. Severity: High (CVSS ~7.5–8.5)

9. Remediation Recommendations

- Disable detailed error messages and stack traces in production environments
- Implement centralized error handling with generic user-facing responses
- Store sensitive data securely using environment variables or secret management systems
- Rotate all exposed credentials and secrets immediately

- Enforce secure logging practices to prevent information leakage

10. Proof of Concept
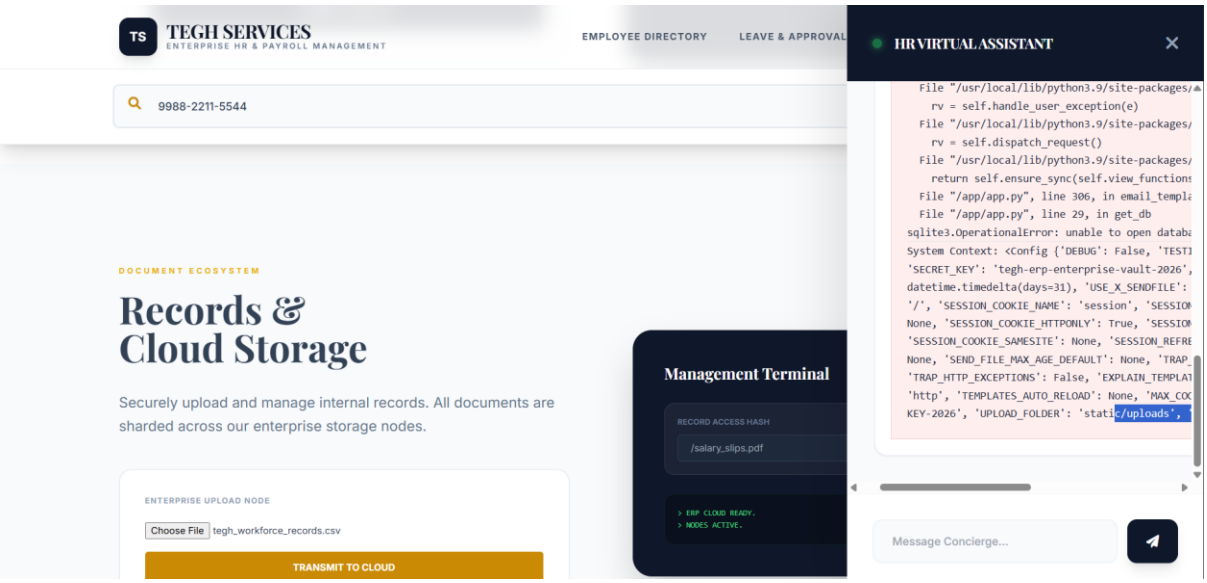
Figure 1: Stack trace exposure and sensitive configuration values (JWT keys, SECRET_KEY) visible in application response